

Princípios da Segurança e o Ciclo de Vida da Segurança da Informação

Resumo do Tema 1 — Introdução à Segurança da Informação

Professor: Ranyere Ney Osório Lima

Grupo: Cauê Lima · Juan Valente · Felipe Costa · Jefferson · Lucas Gabriel

Turma: 3001 · **Período:** 2026.2

O que o Tema 1 cobre

01

Tríade CID

Confidencialidade, Integridade e Disponibilidade

02

Princípios complementares

Autenticidade, não repúdio e legalidade

03

Ciclo de vida da informação

Da criação ao descarte, com risco por fase

04

Ciclo de vida da segurança

Processo contínuo, não ação única

05

Ameaça, vulnerabilidade e risco

Incluindo a conta do ALE

06

Segurança física e lógica

Anéis de proteção, AAA e controle de acesso

A Tríade CID

C

Confidencialidade

Só quem tem autorização acessa a informação.

Quebra: planilha de salários enviada por engano para a empresa toda.

I

Integridade

A informação continua exata e completa em todo o ciclo de vida.

Quebra: alguém altera as notas já lançadas no sistema acadêmico.

D

Disponibilidade

Está acessível quando quem tem direito precisa dela.

Quebra: servidor cai e ninguém trabalha durante horas.

Os três se sustentam juntos: proteger demais um deles costuma derrubar outro. Senha impossível de lembrar protege a Confidencialidade e destrói a Disponibilidade.

Princípios complementares

Autenticidade

Garante que quem enviou é quem diz ser, e que o documento veio mesmo daquela origem.

Sustentada por assinatura digital e certificado.

Não repúdio

Impede que alguém negue depois uma ação que fez no sistema.

Sustentado por log assinado e trilha de auditoria.

Legalidade

O tratamento da informação segue a lei vigente.

No Brasil, LGPD: base legal, finalidade e direito do titular.

Integridade responde *o conteúdo mudou?*; autenticidade responde *veio de quem diz ter vindo?*. São perguntas diferentes e exigem controles diferentes.

Ciclo de vida da informação

Criação

Já nasce classificada, ou não se sabe o que proteger

Armazenamento

Criptografia em repouso e cópia de segurança

Uso

Acesso mínimo e registro de quem abriu

Compartilhamento

Fase mais exposta: dado em trânsito pede criptografia

Arquivamento

Integridade a longo prazo e obsolescência de mídia

Descarte

Apagar não basta: sobrescrever ou triturar

Cada fase tem vulnerabilidade própria e pede controle próprio. Proteger só o armazenamento deixa o vazamento acontecer no compartilhamento ou na lixeira.

Ciclo de vida da segurança

Segurança é processo contínuo, não projeto que termina.

1

Identificar

Levantar ativos, ameaças e vulnerabilidades. Sem inventário não existe proteção.

2

Proteger

Política escrita, controle de acesso, backup e treinamento das pessoas.

3

Monitorar

Log, auditoria e detecção. Controle que ninguém acompanha só existe no papel.

4

Melhorar

Corrigir a falha encontrada e realimentar o ciclo com o que se aprendeu.

É o PDCA da ISO/IEC 27001 aplicado à segurança. O ambiente muda, surge ameaça nova e o controle de ontem envelhece: por isso o ciclo gira sempre.

Ameaça, vulnerabilidade e risco

Ameaça

Evento ou agente com potencial de causar dano. Existe querendo a empresa ou não.

Cibercriminoso, incêndio, falha de hardware, erro humano.

Vulnerabilidade

Fraqueza interna que a ameaça consegue explorar. É o que a empresa controla.

Sistema desatualizado, senha compartilhada, porta destrancada.

Risco

Probabilidade de a ameaça explorar a vulnerabilidade, vezes o impacto.

$\text{Risco} = \text{Ameaça} \times \text{Vulnerabilidade} \times \text{Impacto}$

Servidor sem atualizar é vulnerabilidade; o criminoso que explora a falha é a ameaça; a chance de isso acontecer com o prejuízo que causa é o risco.

Colocando preço no risco

$$\text{ALE} = \text{SLE} \times \text{ARO}$$

SLE

Single Loss Expectancy: perda de um incidente só.

$\text{SLE} = \text{valor do ativo} \times \text{fator de exposição}$

ARO

Annualized Rate of Occurrence: quantas vezes por ano acontece.

Uma vez a cada 10 anos = 0,1

ALE

Annualized Loss Expectancy: perda esperada por ano.

É o teto racional do gasto com o controle

Tratamento do risco: **aceitar** · **mitigar** · **transferir** · **evitar**

Se o ALE é R\$ 20 mil por ano, não faz sentido um controle de R\$ 200 mil por ano. O que sobra depois do controle é o risco residual, aceito formalmente pela direção.

Anéis concêntricos de proteção

1º

Perímetro externo

Muro, cerca, iluminação e câmera. Serve para dissuadir antes de tudo.

2º

Recepção e circulação

Triagem de visitante, crachá e catraca. Registra quem entrou e quando.

3º

Área crítica

Data center com biometria, porta reforçada e dupla custódia.

Controles ambientais: temperatura 18–27 °C · umidade 40–60% · extinção por agente limpo, nunca água · nobreak com gerador

Quem tem acesso físico à máquina tem, mais cedo ou mais tarde, acesso ao dado. Por isso a camada física vem antes da lógica.

Framework AAA

Autenticação

Confirma que o usuário é quem diz ser.

Algo que sabe (senha), que possui (token) ou que é (biometria). MFA combina dois fatores de tipos diferentes.

Autorização

Define o que ele pode fazer depois de entrar.

Modelos DAC, MAC e RBAC, sempre com privilégio mínimo.

Auditoria

Registra o que foi feito durante a sessão.

É o log que sustenta investigação forense e prova de conformidade.

Autenticar sem autorizar entrega o sistema inteiro a qualquer usuário válido. Autorizar sem auditar deixa a organização sem saber o que aconteceu.

DAC, MAC e RBAC

DAC

FLEXÍVEL

Quem cria o arquivo decide quem entra.

Fácil de usar e difícil de padronizar. É o modelo da pasta compartilhada.

MAC

RÍGIDO

O sistema aplica rótulos de sigilo definidos pelo administrador.

Ambiente militar e governamental, onde o usuário não pode afrouxar a regra.

RBAC

MAIS USADO

A permissão fica no cargo, não na pessoa.

Empresa com rotatividade alta: entrou alguém, vincula ao papel e pronto.

Princípio do menor privilégio: conceder só o direito estritamente necessário para o trabalho, e retirar o acesso no mesmo dia do desligamento.

Por que a senha do estudante é um problema

$$E = L \times \log_2(R)$$

A conta

L é o tamanho da senha e R é o tamanho do alfabeto. Com 94 caracteres possíveis, $\log_2(94) \approx 6,55$.

10 caracteres $\times 6,55 = 65,5$ bits de entropia. Aumentar o tamanho rende mais que aumentar o alfabeto.

O risco real

Senha repetida em e-mail, sistema acadêmico e rede social transforma um vazamento em três invasões — é o *credential stuffing*.

Senha emprestada também apaga o não repúdio: o log aponta para o dono, não para quem usou.

Correção: senha longa e única por serviço, guardada em gerenciador, com MFA ligado onde houver. Emprestar acesso nunca, nem para ajudar colega.

Pessoas, processos e tecnologia

Tecnologia

Firewall, criptografia, backup e MFA.
Necessária, e sozinha nunca suficiente.

Processos

Política, classificação, gestão de acesso e resposta a incidente. É o que faz a tecnologia ser usada do jeito certo.

Pessoas

O elo mais fraco e também a primeira linha de defesa. Nenhum controle técnico impede alguém de entregar a senha por telefone.

Na engenharia social nada é quebrado: o atacante pede a credencial e entra pela porta da frente. Treinar, escrever a regra e não punir quem reporta vale mais que comprar mais uma ferramenta.

FIXAÇÃO

Vamos praticar os conceitos

4 questões no formato da atividade, com gabarito comentado

Cálculo de ALE

Uma transportadora tem um servidor de banco de dados avaliado em R\$ 200.000,00. Em caso de incêndio a perda seria total. A probabilidade estimada de incêndio severo é de uma vez a cada 10 anos. Qual é a Expectativa de Perda Anual?

A R\$ 2.000,00

B R\$ 10.000,00

C R\$ 20.000,00

CORRETA

D R\$ 100.000,00

E R\$ 200.000,00

Resolução: $SLE = R\$ 200.000 \times 1,0$ (perda total) = R\$ 200.000. $ARO = 1/10 = 0,1$. $ALE = 200.000 \times 0,1 = R\$ 20.000$ por ano — o teto do que faz sentido gastar em proteção contra incêndio nesse ativo.

Classificação de conceitos

Numa auditoria constata-se que os servidores rodam com sistema desatualizado há mais de seis meses, e que criminosos exploram ativamente essas falhas. A condição dos servidores desatualizados classifica-se como:

A Uma ameaça intencional com potencial de dano.

B Uma vulnerabilidade técnica no ambiente lógico.

CORRETA

C Um risco transferido para provedores externos.

D Uma ameaça natural inerente à infraestrutura.

E Um incidente de segurança em fase de contenção.

Resolução: Software desatualizado é fraqueza interna, portanto vulnerabilidade. Os criminosos são a ameaça. A chance de a ameaça explorar essa fraqueza, com o impacto que causaria, é o risco.

Entropia de senha

Uma nova política exige senha de 10 caracteres combinando maiúsculas, minúsculas, números e símbolos, num alfabeto de 94 caracteres possíveis. Sabendo que $\log_2(94) \approx 6,55$, qual é a entropia alcançada?

A 37,6 bits

B 52,4 bits

C 65,5 bits

CORRETA

D 78,6 bits

E 94,0 bits

Resolução: $E = L \times \log_2(R) = 10 \times 6,55 = 65,5$ bits. Cada caractere a mais soma 6,55 bits; por isso alongar a senha rende mais do que exigir mais tipos de símbolo.

Ciclo de vida da segurança

Uma organização criou políticas, orientou funcionários, definiu controles de acesso, passou a fazer backup e a monitorar os sistemas. Tempo depois identificou novos riscos e atualizou as medidas. Essa atitude demonstra que:

- A A segurança só deve ser tratada quando ocorre um incidente.
- B Uma medida implantada nunca precisa ser modificada.
- C A segurança envolve avaliação, implementação, acompanhamento e melhoria contínua.
- D A segurança depende exclusivamente da instalação de antivírus.
- E A segurança é responsabilidade apenas do setor de TI.

CORRETA

Resolução: É o ciclo de vida da segurança girando: identificar, proteger, monitorar e melhorar. Ameaça nova aparece o tempo todo, então o controle precisa ser reavaliado — segurança é processo, não entrega única.

O fio do Tema 1

Se sobrar uma frase de tudo isso, que seja esta:

A informação é protegida em Confidencialidade, Integridade e Disponibilidade ao longo de todo o seu ciclo de vida, e essa proteção só se sustenta como ciclo contínuo de identificar, proteger, monitorar e melhorar — envolvendo pessoas, processos e tecnologia.